

Agentic Regulatory Compliance System

Problem Statement

1. Background

The bank receives a large number of regulatory advisories within short spans of time — from RBI, CERT-In, and other authorities. Each advisory must be **understood semantically**, converted into concrete action points, routed to the right user groups for compliance, and — critically — the claimed compliance must then be **verified independently from the systems themselves**, not merely accepted on the user group's confirmation. Doing this manually at today's advisory volume is slow, error-prone, and unscalable.

The challenge is to build an **agentic system** that automates this entire lifecycle end to end.

2. Core Tasks

- 1 **Understand and decompose:** semantically parse each advisory and split it into granular, Measurable Action Points (MAPs).
- 2 **Assign:** identify the concerned department for each MAP and route it automatically — leveraging the GRC and/or ticketing tools.
- 3 **Independently verify:** once the user group confirms compliance, the system must initiate its own verification directly against the relevant systems. Only when the system-level check passes can the bank declare itself compliant.

3. Worked Example

3.1 The input — an excerpt from an RBI Master Direction

"26. Conduct of Vulnerability Assessment (VA) / Penetration Testing (PT): (a) For critical information systems and/or those in the De-Militarized Zone (DMZ) having customer interface, VA shall be conducted at least once in every six months and PT at least once in 12 months. Also, REs shall conduct VA/PT of such information systems throughout their lifecycle (pre-implementation, post-implementation, after major changes, etc.)."

3.2 Step 1 — Decompose into Measurable Action Points

The system must understand this paragraph and transform it into MAPs. This one small paragraph yields **ten**:

MAP	Action Point
a	VA to be conducted for critical systems at least once every 6 months
b	VA to be conducted for DMZ systems with customer interface at least once every 6 months
c	PT to be conducted for critical systems at least once every 12 months
d	PT to be conducted for DMZ systems with customer interface at least once every 12 months
e	VA to be conducted pre-implementation
f	PT to be conducted pre-implementation

MAP	Action Point
g	VA to be conducted post-implementation
h	PT to be conducted post-implementation
i	VA to be conducted after major changes
j	PT to be conducted after major changes

3.3 Step 2 — Assign each MAP to the concerned department

For every MAP, the system must identify the responsible department and assign it automatically — for example by creating and routing items in the bank's GRC platform or ticketing tool.

3.4 Step 3 — Verify compliance independently

When the user group confirms completion, the system must **not** take that confirmation at face value. It must verify independently. Taking MAP (a) — “VA for critical systems every 6 months” — as the example, two verification routes exist:

- a **Ticket lifecycle check:** query the ticket/lifecycle management tool to confirm when the vulnerability scan was actually completed.
- b **Source-tool check:** query the tool that performs the activity itself — e.g., Tenable, Rapid7, or Qualys for VA scans — and confirm from the tool's own records that the scan ran and completed within the required window.

4. Solution Expectations

- This is one case; advisories arrive dynamically and vary widely. The solution must be **flexible enough to connect to and consume any type of API** — verification logic cannot be hard-coded to specific tools.
- The agentic pipeline must cover all three stages: semantic decomposition into MAPs, automated assignment, and independent system-level verification.
- Independent verification is acknowledged as the hardest part. Teams must demonstrate **at least one complete end-to-end case** — advisory in, MAPs out, assignment made, and compliance verified from the source system.